INT-2: Киберпогода и группа дарквеб угроз

Тестовое задание по интенсиву
«Мыслить, как хакер: кто станет следующей целью?»

Выполнил работу:
Рустамов Н.Б.

Оглавление

Задача №1. Кто станет следующей целью? 3
Основное задание 3
Необходимые данные и источники 3
Анализ данных каждого источника 3
Объединение информации 5
Методология оценки 5
Формирование выводов 6
Дополнительное задание 6
Задача №2. Атака через поставщика 7
Основное задание 7
Выбор организации и зависимостей 7
Характер связей, процессы и данные 7
Сценарии инцидентов и последствия 8
Оценка рисков 9
Дополнительное задание 9
Задача №3. Автоматизация мониторинга киберугроз 10
Основное задание 10
Источники и сбор публикаций 10
Обработка, классификация и поиск повторов 10
Хранение и демонстрация результатов 11
Дополнительное задание 12
Заключение 13
Список использованных источников 14

Задача №1. Кто станет следующей целью?

Основное задание

Необходимые данные и источники

Для определения возможных целей необходимо учитывать как активность злоумышленников, так и особенности организаций. В работе рассматриваются хактивисты, финансово мотивированные киберпреступники и APT-группировки. Их мотивы различаются: от общественного резонанса и финансовой выгоды до доступа к стратегически важной информации. Поэтому оценивать все компании по одной схеме без разделения категорий было бы неправильно [1].

Для анализа выделены семь групп данных: история атак, публичная активность группировок, сведения о самих группировках, характеристики компаний, политические и общественные события, сведения об уязвимостях, утечки и связи с поставщиками. Ни один из этих источников сам по себе не позволяет достоверно определить следующую цель.

Анализ данных каждого источника

1. Публикации о прошлых атаках. Что собирается: название пострадавшей организации, отрасль, дату, тип атаки, последствия и ссылку на сообщение. Зачем это нужно: прошлые инциденты помогают выявлять часто затрагиваемые отрасли и повторяющийся интерес к отдельным организациям. Обработка и анализ: можно сравнивать число различных событий по компаниям и датам, удалять повторы и отмечать подтвержденные инциденты. Ограничения: публично раскрывается не каждая атака; одно событие часто описывается несколькими СМИ. [12, 13]

2. Заявления злоумышленников и сообщения об их активности. Что собирается: публичные заявления об атаке, упомянутые компании, предполагаемые мотивы, время появления информации и ее источник. Зачем это нужно: прямое упоминание организации может показывать интерес группы именно к ней. Обработка и анализ: такие сообщения необходимо сопоставлять с независимыми публикациями и официальными уведомлениями; учитывать, подтверждено ли само событие. Ограничения: заявления могут быть ложными или преувеличенными; недоступные и непроверенные площадки в автоматическую выборку не включались. [12, 13]

3. Профили группировок. Что собирается: известные цели и отрасли, географию, методы, предполагаемую мотивацию и подтвержденные кампании. Зачем это нужно: это позволяет сравнить профиль рассматриваемой организации с известными интересами

группы. Обработка и анализ: данные MITRE ATT&CK и аналитических публикаций используются для составления профилей и сопоставления повторяющихся методов. Ограничения: атрибуция атак может изменяться, а описания группировок не охватывают все их действия. [1]

4. Информация о компаниях. Что собирается: отрасль, масштаб деятельности, основные продукты, характер обрабатываемых данных и зависимость от внешних сервисов. Зачем это нужно: некоторые характеристики могут повышать привлекательность компании для определенных категорий атакующих. Обработка и анализ: информация из официальных сайтов и публикаций приводится к единому профилю, затем используется в оценке. Ограничения: открытые источники не раскрывают все внутренние системы, а часть корпоративных сведений со временем устаревает. [8-11]

5. Политические и общественные события. Что собирается: даты крупных событий, публичные заявления, изменение общественной повестки и упоминания заинтересованных отраслей. Зачем это нужно: такие события могут быть значимы для анализа мотивации хактивистов и некоторых APT-групп. Обработка и анализ: даты событий можно сопоставлять с динамикой публичных заявлений и сообщений об атаках. Ограничения: совпадение событий по времени еще не подтверждает причинно-следственную связь; необходимы дополнительные свидетельства. [1, 13]

6. Данные об уязвимостях. Что собирается: идентификаторы CVE, затронутые продукты, оценки EPSS и сведения о наблюдавшейся эксплуатации из CISA KEV. Зачем это нужно: эти сведения могут указывать на наличие технических предпосылок для атак. Обработка и анализ: для известных публичных технологий организации можно сопоставлять CVE и сообщения об эксплуатации, не выполняя проверок ее инфраструктуры. Ограничения: наличие CVE в продукте не означает, что компания использует уязвимую версию или что ее уже атаковали. [2-4]

7. Утечки данных и связи с поставщиками. Что собирается: официальные сообщения об инцидентах, затронутые продукты, данные о зависимости организаций от сторонних сервисов. Зачем это нужно: проблема у одного поставщика иногда затрагивает сразу несколько организаций. Обработка и анализ: для каждой связи указываются зависимый процесс, потенциальные последствия и статус подтверждения. Ограничения: факт сотрудничества не доказывает наличие общего доступа или возможность перехода атаки между системами. [5-7, 10]

Объединение информации

Собранные материалы предлагается хранить в общей базе. Для каждого сообщения фиксируются организация, источник, дата, тип события, возможная группировка, ссылка и степень подтверждения. Названия компаний нужно нормализовать: одно предприятие может упоминаться под несколькими вариантами названия. Сообщения об одном событии объединяются, но ссылки на исходные публикации сохраняются.

После этого информация сопоставляется с профилем компании. Например, историю известных инцидентов можно связать с данными о деятельности организации и известными интересами атакующих. При конфликте источников приоритет следует отдавать прямым официальным сообщениям и нескольким независимым подтверждениям. Непроверенные сообщения отмечаются отдельно и не приравниваются к установленным фактам.

Методология оценки

Предлагается оценивать четыре критерия по шкале от 0 до 5: x1 - прямые признаки интереса, x2 - история атак, x3 - характеристики организации, x4 - текущие события и угрозы. Веса различаются для каждой категории злоумышленников (смотреть таблицу 1).

Таблица 1 - веса критериев для разных категорий злоумышленников.

Критерий	**Хактивисты**	**Киберпреступники**	**APT**
Прямые признаки интереса	35 %	30 %	10 %
История атак	20 %	20 %	30 %
Характеристики организации	10 %	30 %	35 %
Текущие события и угрозы	35 %	20 %	25 %

Итоговый индекс рассчитывается по формуле $S = (x1 \cdot w1 + x2 \cdot w2 + x3 \cdot w3 + x4 \cdot w4) / 5$, где w обозначает вес критерия в процентах. Диапазон индекса от 0 до 100. Для сравнения приняты условные уровни: 0-39, 40-69 и 70-100 баллов.

Для хактивистов сильнее учитываются текущая повестка и прямые заявления; для киберпреступников важнее возможная финансовая выгода и интерес к организации; для APT большее значение имеют профиль цели и история соответствующих инцидентов. Если подтверждений недостаточно, оценка не рассчитывается либо сопровождается низкой уверенностью. В техническом прототипе ноль означает, что признак не засчитан в текущей выборке, а не доказанное отсутствие угрозы.

Формирование выводов

Сначала для каждой компании рассчитываются отдельные показатели по трем категориям. Далее сравниваются значения, учитывается число различных подтвержденных событий и анализируется, какие критерии больше всего повлияли на результат. Вывод должен содержать не только балл, но и ссылки на конкретные публикации, пояснение причин и ограничения.

При сравнении компаний нельзя делать вывод о следующей цели только по высокому значению индекса. Правильнее выделять организации, для которых наблюдаются признаки интереса, и указывать степень уверенности. Новые данные могут изменить положение компании в таком списке.

Дополнительное задание

Для проверки подхода написаны два скрипта на Python. collector.py читает открытые RSS-ленты BleepingComputer, The Record и Securelist и может дополнительно искать новости по названиям организаций через Google News RSS. Публикации сохраняются в SQLite с указанием источника, заголовка, ссылки, описания и даты. analyzer.py находит упоминания компаний, подготавливает review.csv для проверки и рассчитывает баллы только по отмеченным публикациям. Использованы пассивные методы [12-15].

На момент анализа в базе было получено 236 публикаций, из них 131 попали в таблицу потенциально подходящих материалов. После проверки для оценки ConnectWise использованы две публикации об отдельных инцидентах: более раннем случае с ScreenConnect и кампании через Cloud Backup в октябре 2026 года [5-7]. Microsoft относит вторую кампанию к Storm-0940, описывая ее как государственно ориентированного атакующего [6] (смотреть таблицу 2).

Таблица 2 - результат практической проверки.

Показатель	**Значение**
Объем базы на момент анализа	236 публикаций
Отобрано для проверки	131 публикация
Различных инцидентов, учтенных в расчете	2
Компания и категория	ConnectWise / APT
Баллы	52 из 100; уверенность низкая

Для ConnectWise использованы значения x1 = 0, x2 = 4, x3 = 4, x4 = 0. История атак получила 4 балла с учётом двух отдельных инцидентов. Характеристики компании также оценены в 4 балла, поскольку её продукты используются для управления ИТ-инфраструктурой клиентов. Поэтому S = (0·10 + 4·30 + 4·35 + 0·25) / 5 = 52.

Для хактивистов и финансово мотивированных киберпреступников достаточного количества подтвержденных данных в собранной выборке не оказалось, поэтому оценки для данных категорий не рассчитывались.

Задача №2. Атака через поставщика

Основное задание

Выбор организации и зависимостей

Для анализа выбрана экосистема VK. Она объединяет пользовательские, облачные и образовательные продукты, поэтому позволяет рассмотреть несколько типов связей. Здесь важно различать техническую зависимость, интеграцию сервиса и обычное сотрудничество. Наличие партнерства само по себе не означает возможность перехода атаки между компаниями.

В модель включены VK ID, VK Cloud, YCLIENTS, Учи.ру, VK Education, условный университет-партнер и внешний компонент «Маруси». Первые четыре типа связи подтверждаются опубликованной документацией или сообщениями организаций [8-11]. Два последних сценария нужны для проверки модели и не представлены как установленные технические зависимости.

Характер связей, процессы и данные

При анализе возможных атак через поставщиков необходимо учитывать характер связей между организациями, а также бизнес-процессы и данные, которые могут быть затронуты в случае возникновения инцидента. Для этого были рассмотрены отдельные сервисы VK и их взаимодействие с другими организациями. Часть связей подтверждена открытыми источниками, остальные рассматриваются в рамках возможных сценариев взаимодействия (смотреть таблицу 3).

Таблица 3 - зависимости, затрагиваемые процессы и статус сведений.

Связь	Процесс и возможные данные	Основание
VK ID / Почта Mail	Вход в учетные записи; идентификаторы и данные авторизации.	Документирована функция входа [8].
VK Cloud / приложения клиентов	Размещение приложений и данных клиентов; доступность облачных ресурсов.	Назначение платформы подтверждено [9].
YCLIENTS / ВКонтакте	Онлайн-запись на услуги, расписание, контактные сведения клиентов в рамках интеграции.	Документирована запись через ВКонтакте [10].
Учи.ру / VK Education	Совместные образовательные мероприятия; регистрация участников при наличии соответствующей системы.	Подтвержден совместный проект; интеграция не установлена [11].
Университет / VK Education	Гипотетический обмен регистрационными данными участников.	Модельное предположение.
Внешний сервис / «Маруся»	Гипотетическая интеграция пользовательской функции.	Модельное предположение.

В таблице отдельно представлены связи, подтвержденные открытыми источниками, и возможные сценарии взаимодействия, используемые для дальнейшего моделирования.

Сценарии инцидентов и последствия

1. VK ID. Условия: нарушение работы центральной авторизации при использовании VK ID подключенными сервисами; компрометация учетных записей требует дополнительных условий. Последствия: Ошибки входа, обращения в поддержку, временная недоступность части функций. При отдельной компрометации механизма авторизации возможен риск доступа к чужим аккаунтам.

2. VK Cloud. Условия: инцидент затрагивает облачные ресурсы, на которых клиент разместил важные приложения; резервные площадки или копии могут отсутствовать. Последствия: Недоступность приложений и замедление бизнес-процессов клиентов, расходы на восстановление.

3. YCLIENTS. Условия: инцидент влияет на запись, расписание или данные клиентов, используемые в интеграции с социальной сетью. Последствия: Невозможность записи через ВКонтакте, перенос услуг, возможная потеря заказов. Утечка возможна только при отдельном доступе к данным.

4. Учи.ру. Условия: инцидент затрагивает часть платформы, которая задействована в совместном образовательном мероприятии. Последствия: Срыв или перенос этапов мероприятия, затруднения регистрации и взаимодействия с участниками.

5. Университет-партнер. Условия: у университета действительно существует совместная программа и обмен определенными данными; эти технические условия в работе не подтверждены. Последствия: Возможные нарушения регистрации и конфиденциальности данных участников, если они находятся у такого партнера.

6. Внешняя интеграция «Маруси». Условия: используемый внешним компонентом интерфейс влияет на функцию помощника; конкретный поставщик не определен. Последствия: Потеря отдельной функции, некорректная обработка команд, возможные вопросы к доступности сервиса.

Оценка рисков

Для сравнения сценариев введены три показателя по шкале 1-5: P - относительная реализуемость выбранного сценария, I - тяжесть последствий, D - степень зависимости процесса от компонента. Индекс риска $R = P \cdot I \cdot D / 125 \cdot 100$ (смотреть таблицу 4).

Таблица 4 - сравнение шести сценариев.

Сценарий	P	I	D	R
VK ID	3	5	5	60,0
VK Cloud	3	5	4	48,0
YCLIENTS	3	4	4	38,4
Учи.ру	3	4	3	28,8
Университет-партнер	2	4	3	19,2
Внешняя интеграция «Маруси»	2	3	3	14,4

Наибольший индекс в модели получился у VK ID (60 баллов), поскольку от входа в сервисы может зависеть много пользователей. Следующий показатель у VK Cloud (48 баллов), где важна доступность клиентских приложений. Для проверки реального риска потребовались бы данные об архитектуре, резервировании, процессах доступа и истории инцидентов, которых в открытых источниках нет.

Дополнительное задание

Для выполнения дополнительного задания была разработана программа на Python. В файле model.py реализованы расчет рисков и определение затронутых процессов. В nodes.csv перечислены организации, сервисы и процессы, в links.csv указаны связи между ними, а в scenarios.csv заданы шесть сценариев инцидентов и их исходные оценки. После запуска программа рассчитывает индекс риска для каждого сценария и сохраняет результаты в results/risks.csv.

На основе данных nodes.csv и links.csv программа при каждом запуске строит граф зависимостей в формате SVG. При изменении узлов или связей схема перестраивается, а изменения в scenarios.csv учитываются при следующем расчёте рисков. Пример графа представлен на рисунке 1.

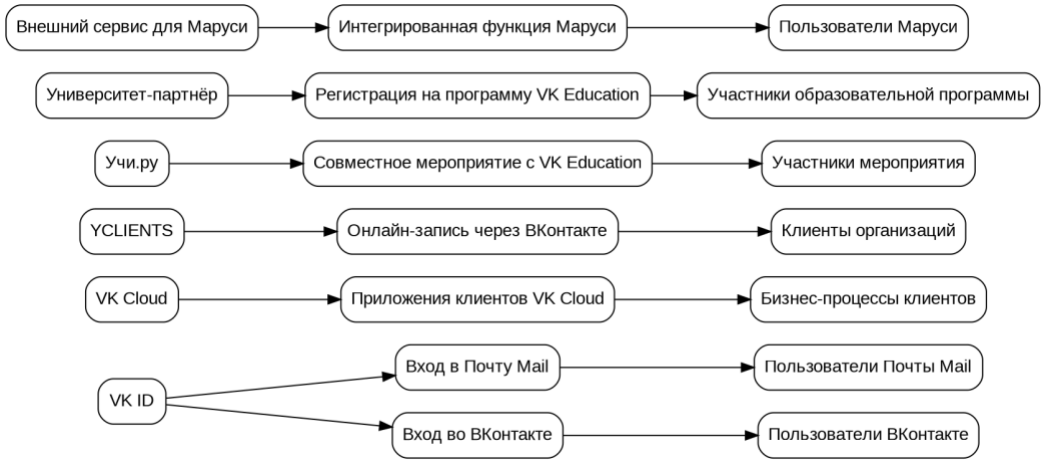


Рисунок 1 - модель зависимостей и направлений возможного влияния инцидента.

Задача №3. Автоматизация мониторинга киберугроз

Основное задание

Источники и сбор публикаций

В качестве источников выбраны открытые RSS BleepingComputer, The Record и Securelist, а также сохраненная выборка Google News RSS. Эти ресурсы сообщают об инцидентах, уязвимостях и исследованиях по кибербезопасности [12-15].

Скрипт monitor.py поддерживает три режима. При запуске с параметром --live он получает свежие записи из публичных RSS. Также он обрабатывает ранее сохраненные публикации из базы первого задания (--from-db) или CSV (--from-csv). При чтении RSS используется стандартный XML-парсер Python, а данные извлекаются из доступных тегов ленты.

Обработка, классификация и поиск повторов

Для каждого сообщения сохраняются источник, дата, автор, заголовок, доступный текст и ссылка. Если в RSS автор отсутствует, ставится пометка «не указан». В приложенной выборке publications.csv сохранены только заголовки, даты, источники и ссылки. Поэтому там автор не указан, а текст описания пустой; программа не пытается восстановить отсутствующие сведения.

Для первичной классификации используются ключевые слова. Например, ransomware относится к вымогательству, leaked data к утечке, CVE к сообщениям об уязвимости (смотреть таблицу 5). Также выделяются продажи доступа, заявления об атаке и другие инциденты. Если подходящих слов нет, ставится категория «Другое».

Таблица 5 - основные правила классификации.

Категория	**Примеры признаков**
Продажа доступа	selling access; initial access broker
Вымогательство	ransomware; extortion
Утечка	data breach; leaked data
Заявление об атаке	claimed attack; hacktivist
Уязвимость	CVE; vulnerability
Фишинг	phishing; vishing
Другие инциденты	compromised; malware; cyberattack

Упоминания компаний определяются по словарю вариантов названий, а домены ищутся регулярным выражением. Повторы выявляются по одинаковой ссылке либо совпадающему заголовку внутри одного источника; поисковые запросы Google News рассматриваются как один агрегатор.

Хранение и демонстрация результатов

После обработки создаются posts.csv с отдельными публикациями, events.csv с предварительными группами, trend.csv с количеством сообщений по датам и база monitor.sqlite3. Структурированное хранение позволяет фильтровать сообщения по категориям, компаниям и времени без повторного сбора данных.

Для воспроизводимого примера обработаны 88 записей из ранее сохраненной выборки. После удаления повторов осталось 70 публикаций, из которых программа сформировала 51 предварительную группу. В 46 группах обнаружены признаки киберугроз по правилам классификации. Восемь групп содержат публикации с указанием двух и более разных издателей (смотреть таблицу 6).

Таблица 6 - результаты программы мониторинга.

Показатель	**Значение**
Исходные записи	88
Уникальные публикации	70
Предварительные группы	51
Группы с признаками угроз	46
Группы с двумя и более указанными издателями	8

Дополнительное задание

Реализовано сопоставление похожих публикаций и расчет их условного приоритета. Сообщения могут попасть в одну предварительную группу, если совпадает категория, найдена общая компания, даты различаются не более чем на 10 дней и заголовки содержат достаточное число общих слов. Обычные новости из категории «Другое» не объединяются на этом основании.

Для каждой группы определяется наиболее ранняя публикация среди собранных сообщений. Дополнительно рассчитывается приоритет, который зависит от типа события, упоминания компаний и количества различных указанных издателей. Полученные значения используются для сортировки публикаций и выделения наиболее интересных сообщений.

Отдельно рассчитывается ежедневное количество сообщений. Максимум в данной сохраненной выборке пришелся на 21 октября 2026 года, когда было восемь записей. Такой пик характеризует именно собранные заголовки, а не количество реальных кибератак. Для полноценного мониторинга потребовалась бы более широкая выборка и проверка значимых событий аналитиком.

Заключение

В первой задаче предложен подход к оценке интереса разных категорий злоумышленников. Для семи групп источников рассмотрены необходимые данные, способы обработки и ограничения. В дополнительной части реализован пассивный сбор публикаций и расчет условного индекса. Для ConnectWise получено 52 балла по категории APT при низкой уверенности.

Во второй задаче рассмотрены зависимости и шесть возможных сценариев инцидентов, связанных с сервисами и партнерами VK. Для каждого сценария указаны условия реализации и возможные последствия. Дополнительная программа позволяет рассчитать индекс риска и показать затрагиваемые процессы. При этом подтвержденные отношения отделены от предположений модели.

В третьей задаче реализован сбор и первичная обработка открытых публикаций. Программа выделяет доступные сведения о сообщениях, классифицирует заголовки, ищет компании и домены, удаляет повторы и сохраняет результаты в CSV и SQLite. Дополнительно выполняются группировка похожих сообщений, определение приоритета и подсчет активности по дням.

Практическая проверка показала, что открытые публикации могут использоваться для первичного анализа киберугроз, но автоматический результат требует проверки. Особенно важно отличать упоминание компании от сообщения об атаке на нее, а технические зависимости от обычного сотрудничества.

Список использованных источников

1. MITRE ATT&CK: база тактик и техник [Электронный ресурс]. Режим доступа: https://attack.mitre.org/ (дата обращения: 21.10.2026).

2. National Vulnerability Database (NVD) [Электронный ресурс]. Режим доступа: https://nvd.nist.gov/ (дата обращения: 21.10.2026).

3. FIRST. Exploit Prediction Scoring System (EPSS) [Электронный ресурс]. Режим доступа: https://www.first.org/epss/ (дата обращения: 21.10.2026).

4. CISA. Known Exploited Vulnerabilities: репозиторий [Электронный ресурс]. Режим доступа: https://github.com/cisagov/kev-data (дата обращения: 21.10.2026).

5. ConnectWise. Trust Center: Advisories [Электронный ресурс]. Режим доступа: https://www.connectwise.com/company/trust/advisories (дата обращения: 21.10.2026).

6. Microsoft Security Blog. AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise (21.10.2026) [Электронный ресурс]. Режим доступа: https://www.microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/ (дата обращения: 21.10.2026).

7. The Record. ConnectWise says nation-state attack targeted multiple ScreenConnect customers (29.05.2025) [Электронный ресурс]. Режим доступа: https://therecord.media/connectwise-nation-state-attack-targeted-some-customers (дата обращения: 21.10.2026).

8. Почта Mail. Mail и VK ID: справка [Электронный ресурс]. Режим доступа: https://help.mail.ru/mail/faq/vkid/ (дата обращения: 26.10.2026).

9. VK. VK Tech инвестирует 200 млн рублей в импортозамещение платформ виртуализации (25.02.2026) [Электронный ресурс]. Режим доступа: https://vk.company.ru/ru/press/releases/12236/ (дата обращения: 26.10.2026).

10. YCLIENTS. Онлайн-запись во ВКонтакте [Электронный ресурс]. Режим доступа: https://support.yclients.ru/674 (дата обращения: 26.10.2026).

11. VK. VK Education и Учи.ру запускают геймджем по созданию веб-игр (15.04.2026) [Электронный ресурс]. Режим доступа: https://vk.company.ru/ru/press/releases/12282/ (дата обращения: 26.10.2026).

12. BleepingComputer. RSS-лента [Электронный ресурс]. Режим доступа: https://www.bleepingcomputer.com/feed/ (дата обращения: 30.10.2026).

13. The Record. RSS-лента [Электронный ресурс]. Режим доступа: https://therecord.media/feed (дата обращения: 30.10.2026).

14. Securelist. RSS-лента [Электронный ресурс]. Режим доступа: https://securelist.com/feed/ (дата обращения: 30.10.2026).

15. Google News. Поиск публикаций через RSS [Электронный ресурс]. Режим доступа: https://news.google.com/rss (дата обращения: 30.10.2026).